

[/]

FIRST/

Practical AWS Anti-forensics

Jun 19 · Santiago Abastante



/intro

Santi Abastante

- Former Police Officer
- Cloud Security Engineer
- Incident Responder



“Techniques and tools used to **obstruct, deceive, or destroy digital evidence** to hinder digital forensic investigations”

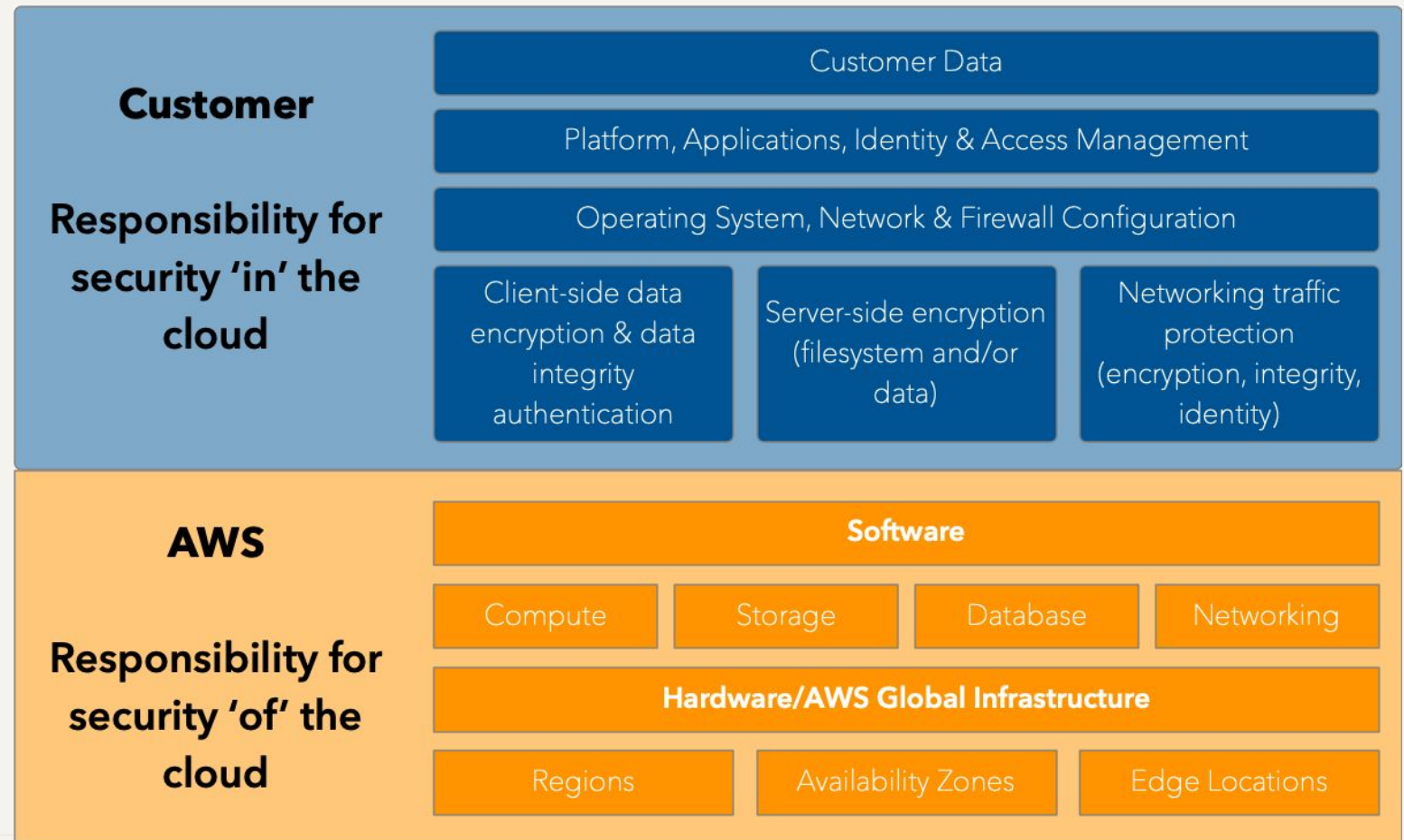
– dbnz/

[02]

Intro

The Share Responsibility Model

- Establishes **who owns what**, the Cloud Provider or the Cloud User,
- Security can not be delegated,
- It also means **we struggle to add visibility controls**,
- Attackers can take advantage of the lack of visibility to execute attacks.
- Example: Lambda Functions and EDR



Cloud Segmentation

- Cloud Providers distribute their infrastructure in different parts of the world,
- Most AWS Services are Regional,
- Some of them are Global,
- **Security Services must be enabled in every active Region.**
- Attackers can exploit Global endpoints to evade defenses.



[02]

AWS Logging and Monitoring

AWS Logs

Log Source

- AWS API Calls
- Netflow
- Services

AWS Service

- Cloudtrail
- VPC Flow Logs
- Every Service has its logs

Log Format

- Json
- Space Delimited Strings
- Every service logs in their own way

Cloudtrail

- **Every Service in AWS is an API,**
- **Cloudtrail Logs every API Call,**
- Can be consumed in 3 ways, each one with different delays and tradeoffs,
- Can be consumed using S3, Cloudwatch or Event Bridge,
- Most important Forensic Artifact for IR,
- **Most integrations require the creation of additional infrastructure,**
- **Some API Call require additional configurations.**

JSON Attributes

```
{
  "aws": {
    "invoked_function_arn": "arn:aws:lambda:us-east-1:822214488732:function:DatadogIntegration-ForwarderStack-2201BQ-Forwarder-xq3glgDLReS7",
    "s3": {
      "bucket": "aws-cloudtrail-logs-822214488732-0b4c59e6",
      "key": "AWSLogs/822214488732/CloudTrail/us-east-1/2025/09/30/822214488732_CloudTrail_us-east-1_20250930T0920Z_RV4Y2o9U4pKnx24c.json.gz"
    }
  },
  "awsRegion": "us-east-1",
  "eventCategory": "Management",
  "eventID": "b0074c80-08d3-3d8e-b77d-64b73dde96ea",
  "eventName": "AssumeRole",
  "eventSource": "sts.amazonaws.com",
  "eventTime": "2025-09-30T09:16:08Z",
  "eventType": "AwsApiCall",
  "eventVersion": "1.08",
  "evt": {
```

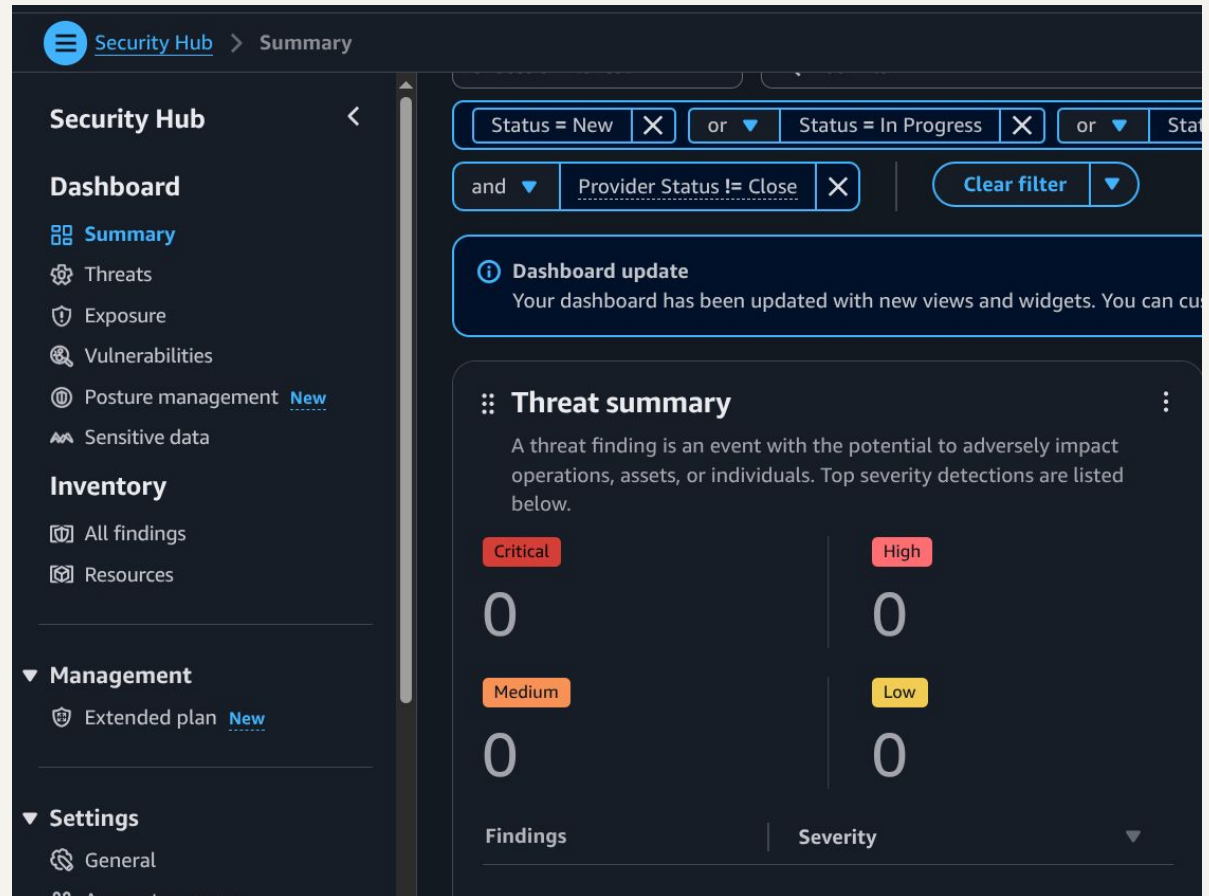
Guardduty

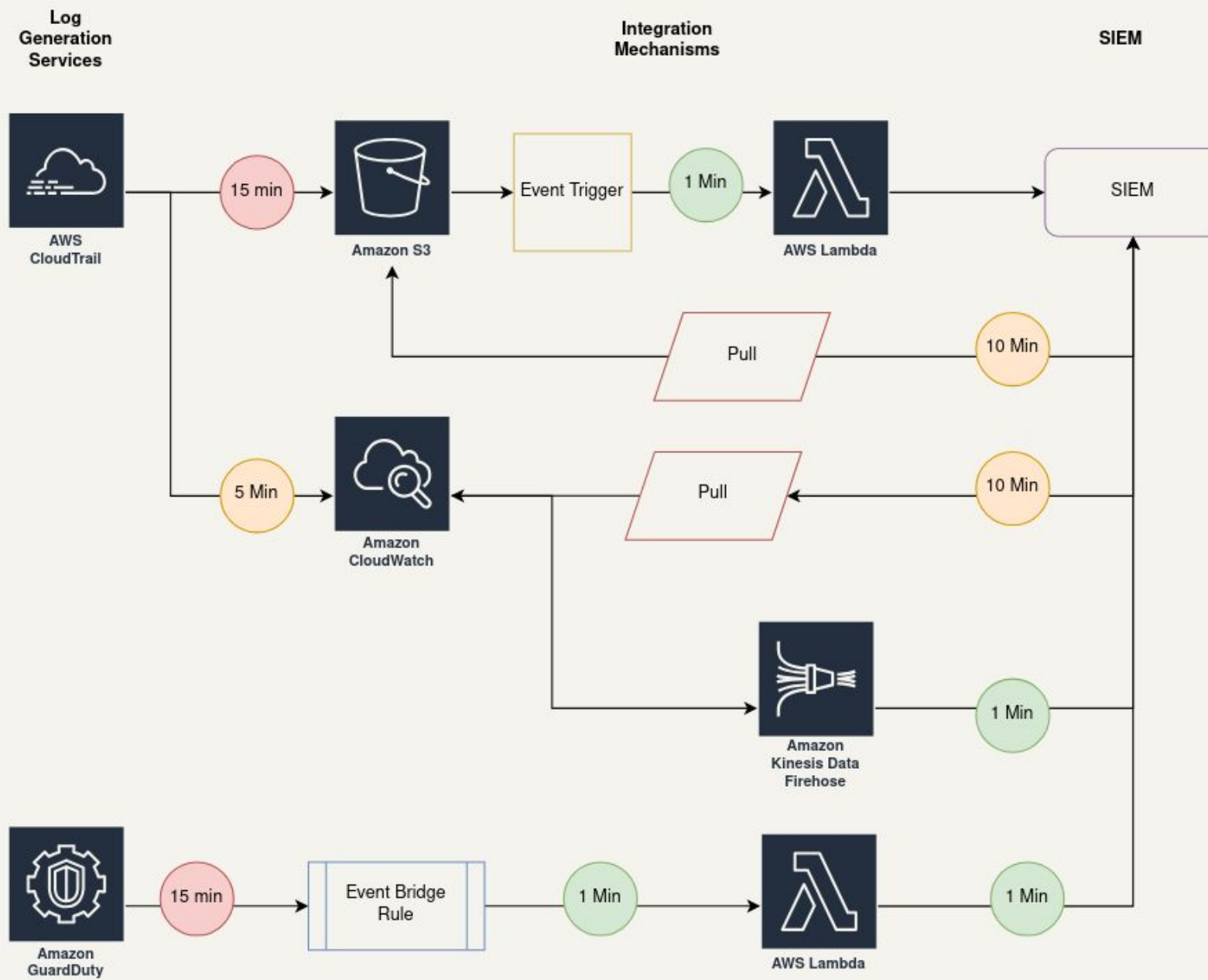
- AWS Threat Detection and Response,
- **Correlates events from API Logs, Network Logs, DNS, Logs, etc,**
- Cannot create custom rules,
- Uses IA for detection;
- **Delays: Up to 15 Min,**
- It gets better every year.



AWS Security Hub

- AWS Security Posture Management and **Findings Aggregation**,
- Consolidates findings from GuardDuty, Inspector, Macie, IAM Access Analyzer, Partner Integrations, and Custom Sources,
- Supports custom findings ingestion through the AWS Security Finding Format (ASFF),
- **Provides centralized visibility, prioritization, and workflow integration for security findings,**
- Delays: Near real-time for findings ingestion, typically seconds to a few minutes depending on the source service.

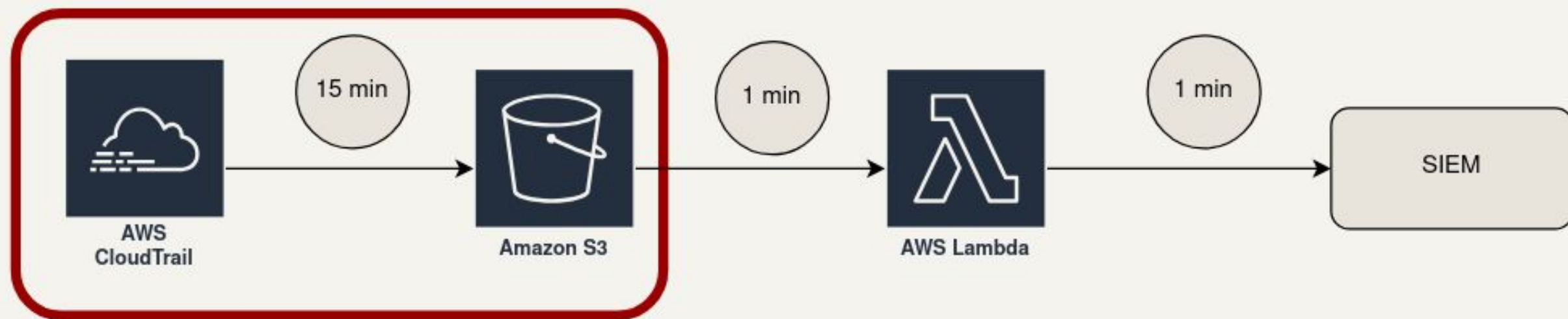


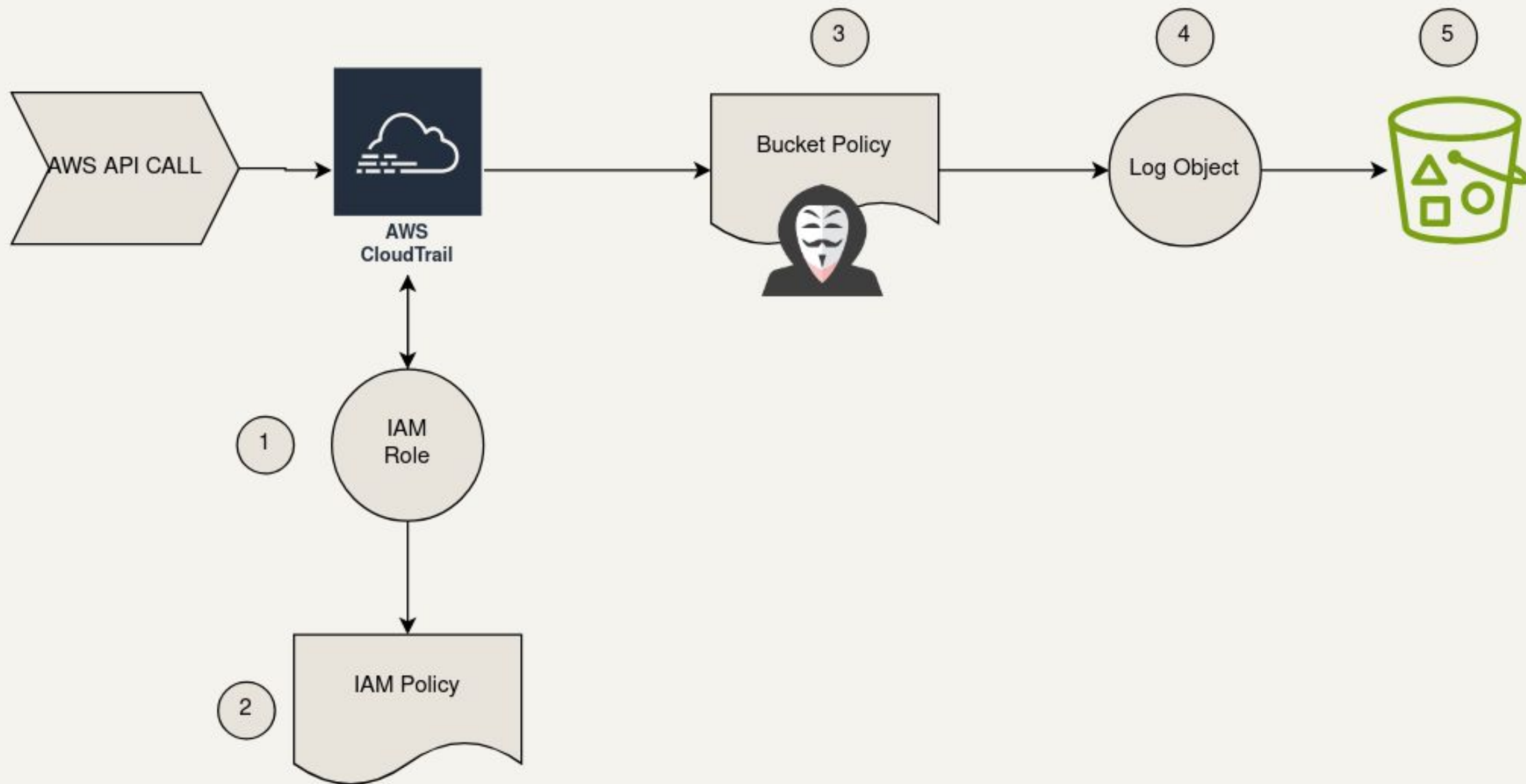


[03]

Antiforensics

Log Generation Supply Chain





Cloudtrail S3 Real Bucket Policy

```
{
  "Sid": "AWSCloudTrailWrite20150319-70e1f2a6-6323-443a-89d8-9dac225465b1",
  "Effect": "Allow",
  "Principal": {
    "Service": "cloudtrail.amazonaws.com"
  },
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3:::aws-cloudtrail-logs-[REDACTED]2-0b4c59e6/AWSLogs/[REDACTED]2/*",
  "Condition": {
    "StringEquals": {
      "AWS:SourceArn": "arn:aws:cloudtrail:us-east-1:[REDACTED]2:trail/soli_demo",
      "s3:x-amz-acl": "bucket-owner-full-control"
    }
  }
}
```


Compromised Bucket Policy

```
{
  "Sid": "AWSCloudTrailWrite20150319-5873720b-cc40-44a0-af55-5e30b039ba28",
  "Effect": "Allow",
  "Principal": {
    "Service": "guardduty.amazonaws.com"
  },
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3:::aws-cloudtrail-logs-8[REDACTED]2-0b4c59e6/AWSLogs/82[REDACTED]/**",
  "Condition": {
    "StringEquals": {
      "AWS:SourceArn": "arn:aws:cloudtrail:us-east-1:8[REDACTED];2:trail/soli_demo",
      "s3:x-amz-acl": "bucket-owner-full-control"
    }
  }
}
```

Issues

- SIEM Trigger Alerts when there is no new logs.
- Cloudtrail Validates if it can access the bucket.

General details

Trail logging

✖ Bucket access denied [Fix policy](#)

Trail name

sol_i_demo

Multi-region trail

Yes

Apply trail to my organization

Not enabled

Trail log location

aws-cloudtrail-logs-822214488732-0b4c59e6/AWSLogs/822214488732 [↗](#)

Last log file delivered

September 09, 2025, 09:01:34 (UTC-03:00)

Log file SSE-KMS encryption

Not enabled

Making it PROD Ready

```
{
  "Sid": "DenyCloudTrailSAEast1",
  "Effect": "Deny",
  "Principal": {
    "Service": "cloudtrail.amazonaws.com"
  },
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3:::aws-cloudtrail-logs-8:2-0b4c59e6/AWSLogs/8/
CloudTrail/sa-east-1/*"
}
```

Making it PROD Ready (2)

2025/

Objects

Properties

Objects (4)

Copy S3 URI

Copy URL

Objects are the fundamental entities stored in Amazon S3. You can to explicitly grant them permissions. [Learn more](#)

Find objects by prefix

☐	Name	Type
☐	05/	Folder
☐	06/	Folder
☐	07/	Folder
☐	08/	Folder

soli_demo

General details

Trail logging

Logging

Trail name

soli_demo

Multi-region trail

Yes

Apply trail to my organization

Not enabled

Trail log location

aws-cloudtrail-logs-8-0b4c59e6/AWSLogs/8:

Last log file delivered

September 09, 2025, 09:11:25 (UTC-03:00)

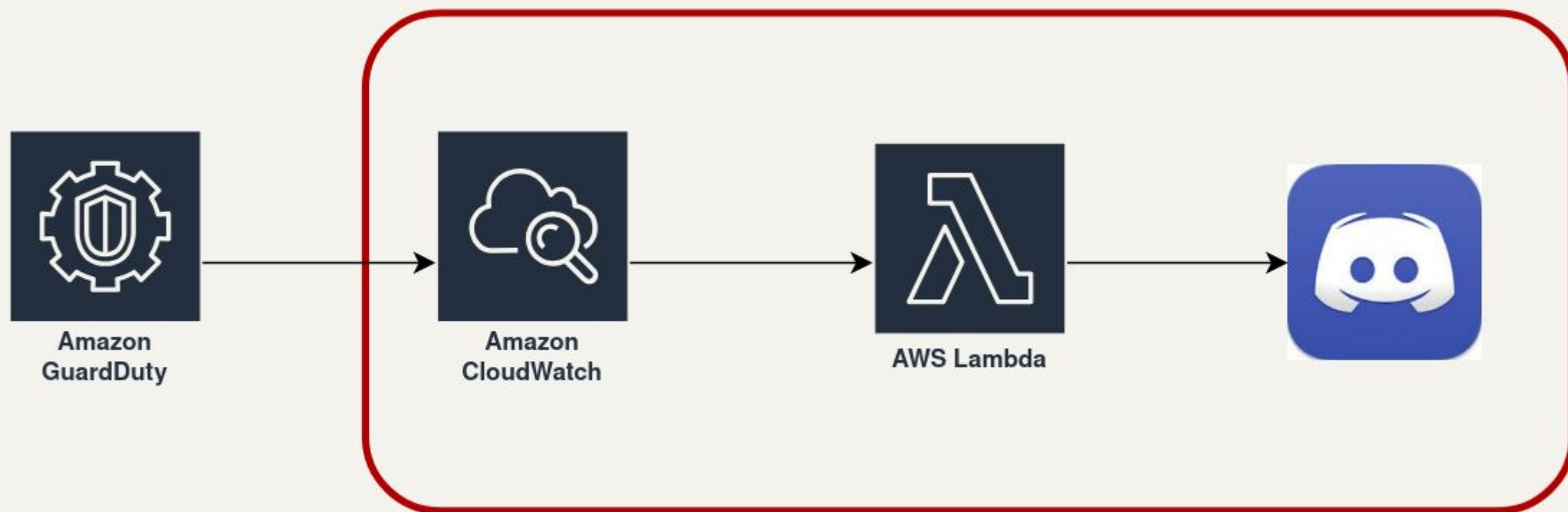
Log file SSE-KMS encryption

Not enabled

[03]

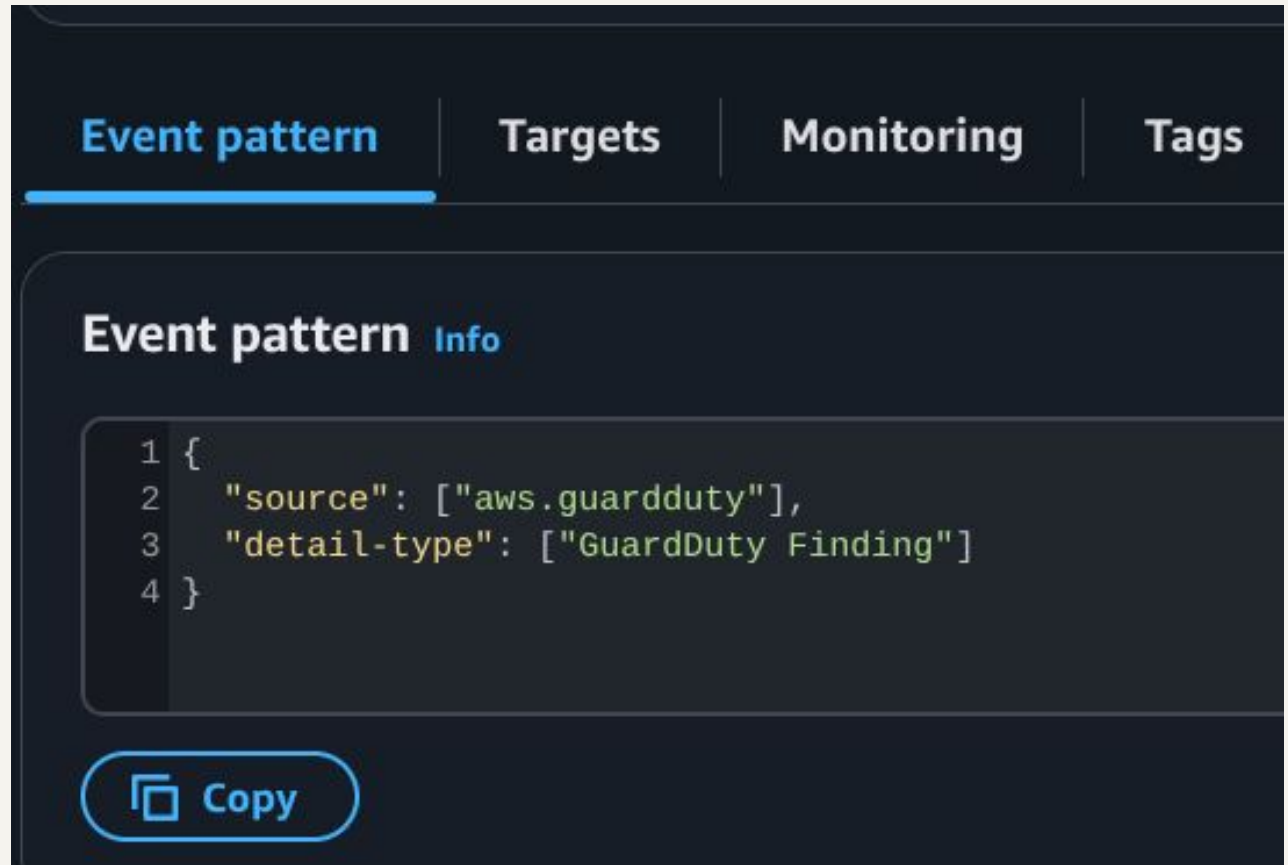
Impair Defenses - Security Detection

Guardduty



Guardduty Event Bridge Rule

- Event Bridge Rules **parses the bus to identify which events to forward** to the target,
- Traditional targets are Lambda Functions, SNS Topics or SQS,
- **We can work with the json schema to impair the defenses**



Guardduty Event Bridge Rule

Event pattern

Write an event pattern in JSON. You can test the event pattern against the sample event. You can also

Prefix matching ▼

Insert



Content-based filter syntax

```
1 {
2   "source": ["aws.guardduty"],
3   "detail-type": ["GuardDuty Finding"],
4   "detail": {
5     "service": {
6       "action": {
7         "awsApiCallAction": {
8           "remoteIpDetails": {
9             "ipAddressV4": [ { "anything-but": ["82.183.9.216"] } ]
10          }
11        }
12      }
13    }
14  }
15 }
```


[/]

Demo/

Impair Defenses for Antiforensics

[04]

Best Practices

”AWS Security is 90% IAM Management and 10% what goes wrong when IAM Management Fails.”

– dbnz/

Preparation: IAM Management

- IAM Users and Groups - With Access Keys
- IAM Roles - With Session Tokens
- AWS Identity Center (SSO) - The Mature Way
- AWS IAM Policies - Inline | Attached | Permissions Boundaries

Access keys (1) [Create access key](#)

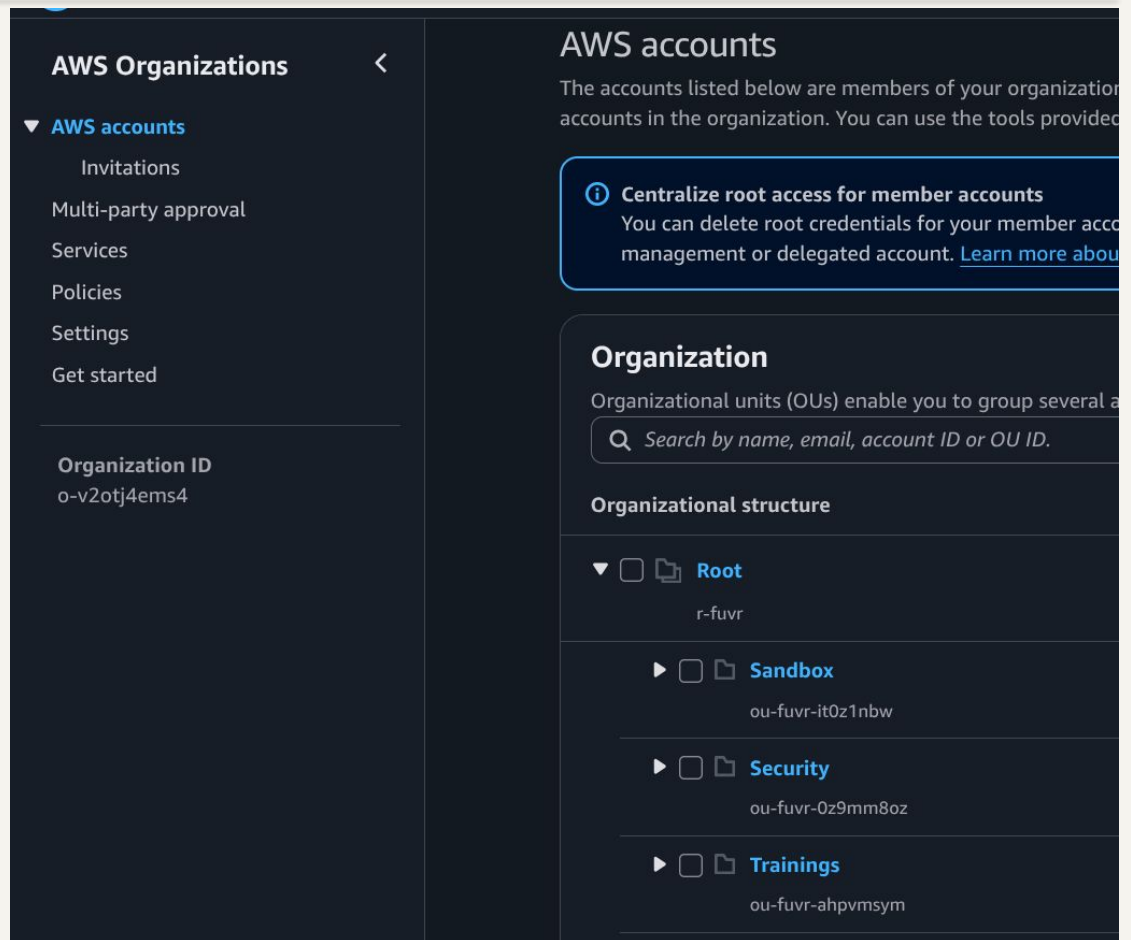
Use access keys to send programmatic calls to AWS from the AWS CLI, AWS Tools for PowerShell, AWS SDKs, or direct AWS API calls. You can have a maximum of two access keys (active or inactive) at a time. [Learn more](#)

AKIAZPLKLRX4DRWBSCWN	Status ⊖ Inactive
Description -	Created 29 days ago
Last used 29 days ago	Last used service s3
Last used region us-east-1	

Actions ▼

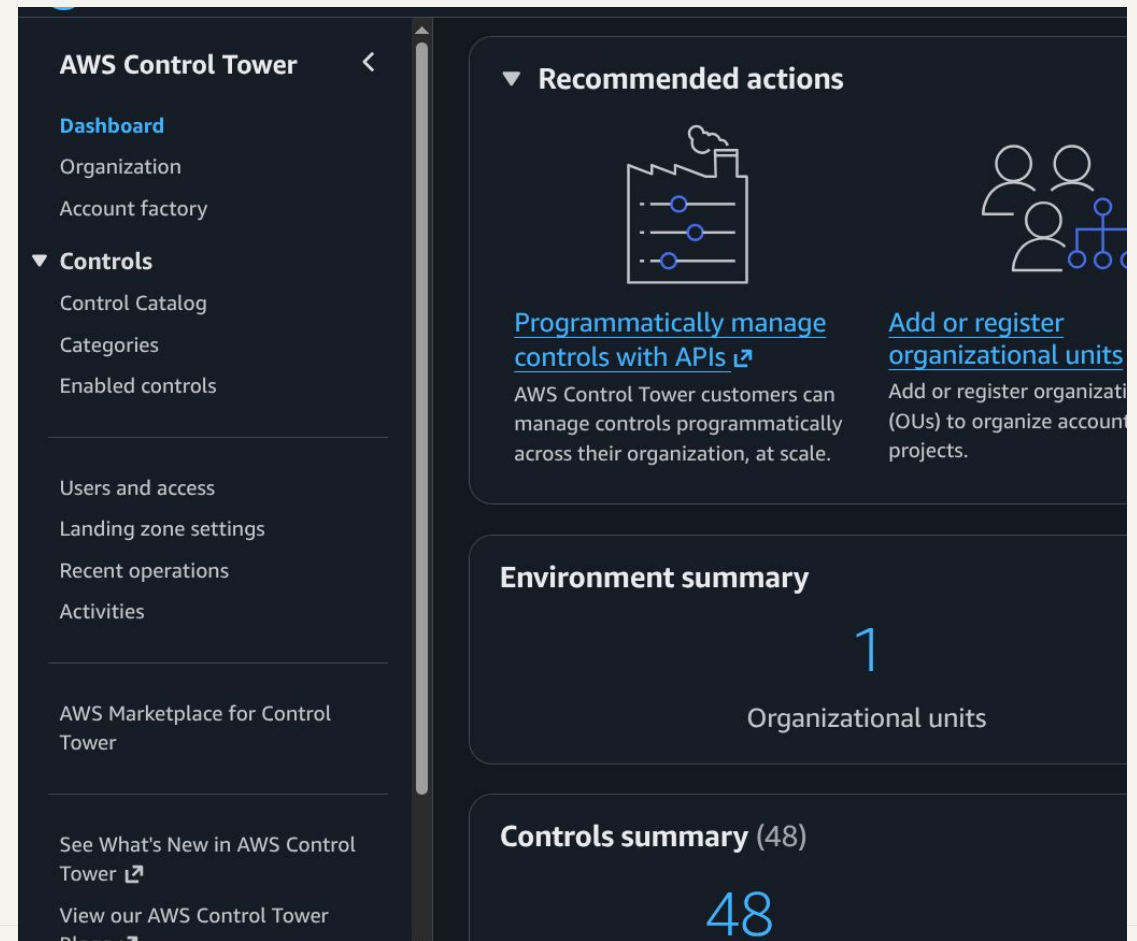
Preparation: AWS Organizations

- AWS Organizations allow the management of multiple AWS Accounts,
- **Security Services enabled at an organization level can not be override at Account level,**
- Service Control Policies are Org wide or account wide security controls that can be enabled.
- There must be a Master account.



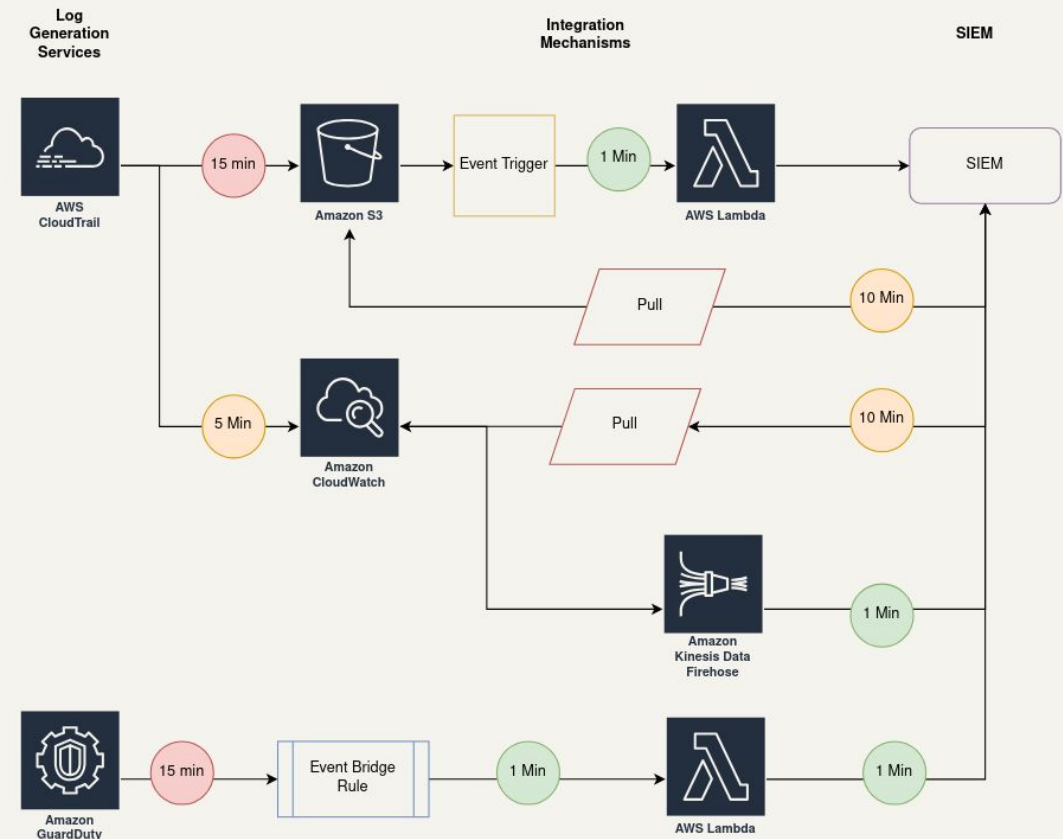
Preparation: AWS Control Tower

- AWS Control Tower is AWS Organization with steroids,
- Allow us to create a Landing Zone, **with a default set of Security Controls**,
- We can create Organizational Units to manage AWS Accounts with different level of security controls,
- **It offers a Control Catalog that hardens the AWS Accounts for malicious behaviors**,
- The most important control is the one that allows us to block unused regions or services,
- It creates a lot of resources in our accounts, must be used with caution because **it can generate cost spikes**.



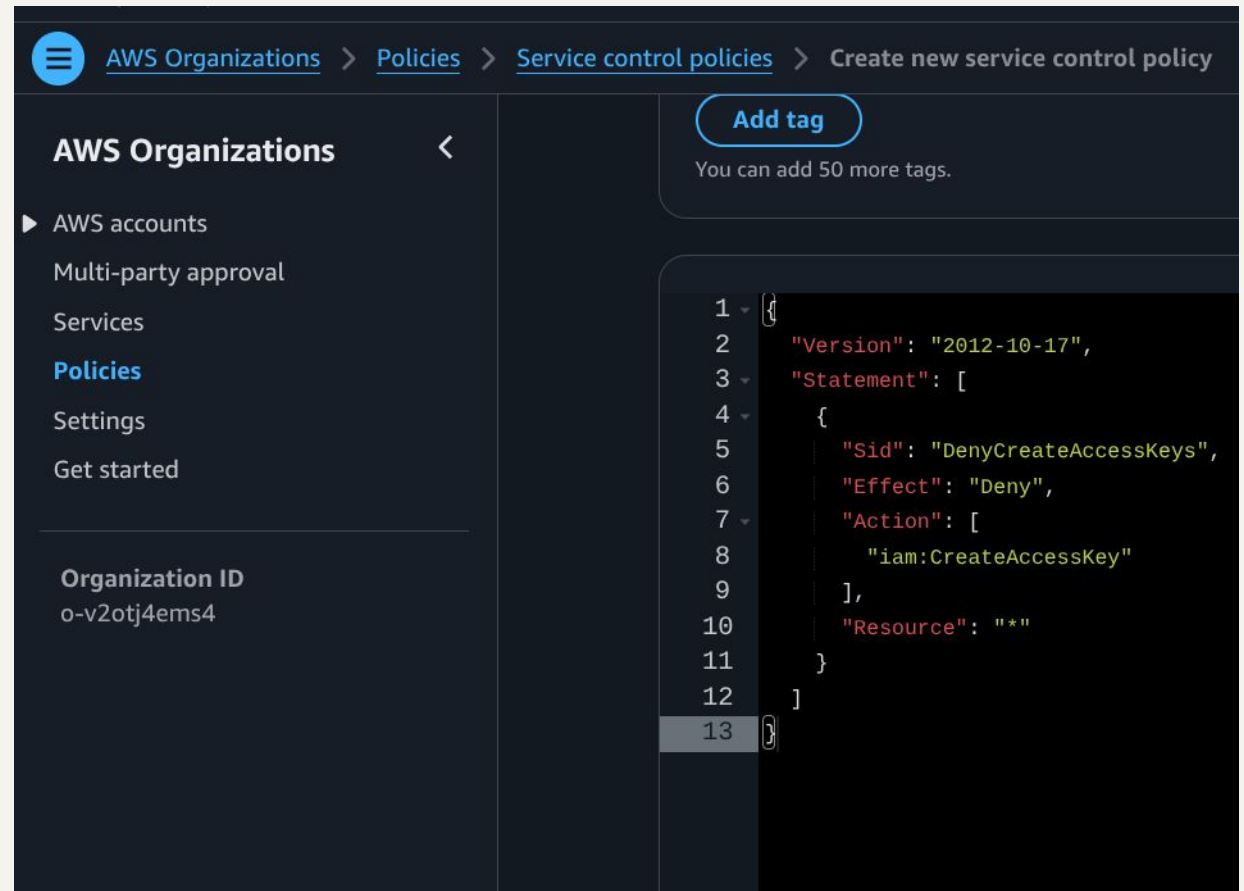
Preparation: Anti Tampering for Detection

- We must be aware of our **detection architecture moving parts**,
- **Detection rules must be implemented if those moving parts are modified**,
- If possible, **automated response** must be implemented,
- Deploying them with **Cloudformation** allows us to implement **Drift Detection**, which will monitor and correct deviations automatically,
- Using infrastructure as Code also works,
- **Having proactive measures that verify the integrity of our architecture is a must.**



Containment: AWS Organization Containment

- Organizations and SCP are powerful for account and org wide containment,
- Create SCP to block malicious behaviors that won't impact the business,
- **Block service creation, Access Keys and Secret Access Key creation**, Impair Defenses techniques, etc.
- If Control Tower is enabled, you can also implement **Proactive controls** that will patch the environment,



[/]

Questions?

Practical AWS Antiforensics

06/19/2026 · Santiago Abastante

Linkedin: Santi Abastante - sabastante

Contact



Slides

